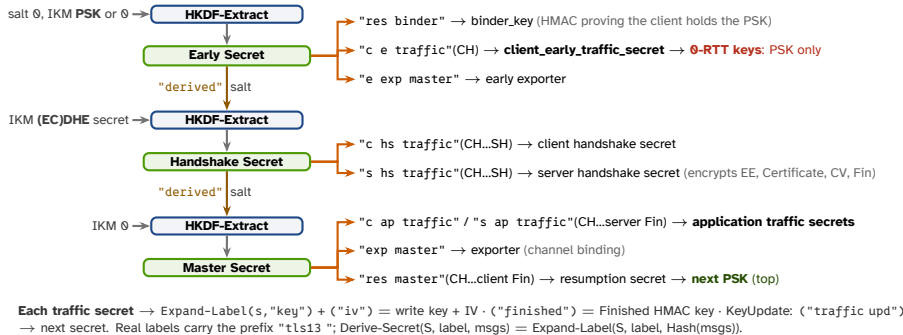


In one line: TLS 1.3 (RFC 8446) feeds its input secrets — a **PSK** and the **ECDHE** result — through three **HKDF-Extract** stages (**Early** → **Handshake** → **Master**); every key is an **HKDF-Expand-Label** of one of them *bound to the transcript hash*, so each phase and direction has independent keys. Records are AEAD-sealed with a **per-record nonce**. A **ticket** makes a PSK for resumption; **0-RTT** data is **replayable**; **ECH** hides the SNI.

Key schedule (RFC 8446 §7.1)



One record on the wire (§5.2)

17	03 03	Len	AEAD ciphertext	tag
5-byte header, clear: al-ways "app data, TLS 1.2" padding (hides length) plaintext $\leq 2^{14} \cdot B$ · ciphertext $\leq 2^{14} + 256 \cdot B$ · the header is the AAD				
nonce = write_iv XOR 64-bit sequence number. Seq restarts at 0 per key and is never sent → a dropped, reordered or replayed record fails the tag. AES-GCM: KeyUpdate before $\approx 2^{24.5}$ full records (§5.5).				

RTTs to the response (100 ms RTT)

TCP + TLS 1.2 full	4	400 ms
TCP + TLS 1.3	3	300 ms
TCP + TLS 1.3 + 0-RTT	2	200 ms + DNS. A reused
QUIC (TLS 1.3 inside)	2	200 ms connection pays 1.
QUIC + 0-RTT	1	100 ms

How the key schedule works

- Extract** = HMAC(salt, input): concentrates entropy. **Expand-Label** derives keys with a *label* + *transcript hash* as context — a key is valid for one role, one direction, one exact conversation (tampered hello ⇒ other keys ⇒ Finished fails).
- No ECDHE (psk_ke) ⇒ input 0 ⇒ **no forward secrecy**. **Finished** = HMAC(finished_key, transcript hash).
- SSLKEYLOGFILE dumps these traffic secrets: enough to decrypt a capture, not to impersonate.

Resumption and 0-RTT (§4.6.1, §8)

- Post-handshake **NewSessionTicket**: lifetime ≤ 7 days, ticket_age_add, nonce, opaque ticket (usually the PSK sealed under a server *ticket key* — stateless).
- Next CH: pre_shared_key (identity, obfuscated age, **binder**) + mode psk_dhe_ke (fresh ECDHE, FS) or psk_ke. Saves certificate + signature (*CPU*), still 1 RTT.
- 0-RTT** (early_data): app data right behind the CH, keyed from the PSK alone — a captured flight can be **replayed**. Defences (§8): single-use tickets · ClientHello recording · freshness window. HTTP (RFC 8470): **425 Too Early**; proxies add Early-Data: 1.

Example — look inside a real connection

```
openssl s_client -connect example.com:443 -tls1_3 \
  -servername example.com -alpn h2,http/1.1 \
  -status -sess_out s.pem -keylogfile keys.txt
# -status: print the stapled OCSP answer, if any
openssl s_client -connect example.com:443 \
  -sess_in s.pem -early_data get.txt # resume + 0-RTT
# keys.txt: CLIENT_TRAFFIC_SECRET_0 ... (for Wireshark)
```

SNI and ECH

SNI (RFC 6066) is *cleartext*. **ECH**: RFC 9849, **March 2026** (+ RFC 9848: config in the DNS **HTTPS** record). An **outer** CH names the provider's public_name; the **inner** CH (real SNI, ALPN) is **HPKE**-encrypted to the provider's key; stale key → retry_configs; **GREASE** ECH hides who really uses it. Plain DNS or a dedicated IP still leak. **Apple**: sec_protocol_options_set_enable_encrypted_client_hello (Network framework) is documented "experimental", default off; no URLSession switch (*unverified*).

Revocation — why lives got short

CRL	signed list of revoked serials; big, stale until reissued
OCSP stapling	live query: leaks browsing to the CA, costs an RTT, soft-fails server attaches a signed OCSP answer (1.3: in the Certificate entry)
short-lived	nothing to revoke — the cert dies first

Let's Encrypt **shut OCSP down 6 Aug 2025** (CRLs only); **6-day certs** GA 15 Jan 2026. CA/B **SC-081**: max cert life **200 d** from 15 Mar 2026 → **100 d** (2027) → **47 d** (2029): automate renewal.

ALPN, QUIC, post-quantum, reuse

- ALPN** (RFC 7301): CH offers h2, http/1.1; server picks in **EncryptedExtensions**. h3: advertised via Alt-Svc (RFC 9114), then ALPN h3 inside QUIC.
- TLS in QUIC** (RFC 9001): no TLS records — handshake bytes in **CRYPTO** frames; packet keys from the same secrets ("quic key", "quic iv", "quic hp"). **Initial** packets are keyed from the Destination Connection ID + a public salt: obfuscated, *not* secret.
- iOS 26**: URLSession/Network offer hybrid **X25519MLKEM768** by default; the bigger ClientHello breaks some legacy servers that can't read large ones (Apple's warning).
- Reuse beats tuning**: one long-lived URLSession per config (its pool keeps h2/h3 alive), never one per request. ARMv8 AES instructions make AES-GCM cheap on phones (*unverified*).

Traps

- ! "Resumption saves an RTT" — in 1.3 only **0-RTT** does, and it is replayable: idempotent requests only.
- ! Stolen **ticket key** → every PSK → all 0-RTT data and psk_ke sessions. Rotate it.
- ! OCSP soft-fail stops no attacker who can block the responder.
- ! Legacy_session_id, 0x0303 in 1.3: middlebox camouflage.

Remember

"Extract × 3 — Early, Handshake, Master; every key an Expand bound to the transcript."